

# Bait AI) بيت المندي – PROJECT FULL AUDIT REPORT (Mandi

**Project:** Bait AI Mandi – Yemeni Restaurant PWA

**Version:** 0.1.0

**Framework:** Next.js 14.2.3 (App Router) + Supabase + Drizzle ORM + PWA

**Audit Date:** 18 June 2026

**Scope:** 10-Phase Comprehensive System Audit (114 source files, 18 migrations, 40+ dependencies)

**Audit Method:** Static code analysis, import map verification, dependency cross-reference, security review, performance profiling

## Table of Contents

|                                                          |     |
|----------------------------------------------------------|-----|
| Executive Summary                                        | .1  |
| Project Statistics                                       | .2  |
| Phase 1: Architecture & Structure Analysis               | .3  |
| Phase 2: Dependency & Import Map Analysis                | .4  |
| Phase 3: Package & Dependency Audit                      | .5  |
| Phase 4: Database & Migration Analysis                   | .6  |
| Phase 5: Security Audit                                  | .7  |
| Phase 6: PWA & Offline Capability Audit                  | .8  |
| Phase 7: Performance Analysis                            | .9  |
| Phase 8: Business Logic & State Management Audit         | .10 |
| Phase 9: Dead Code & Unused Assets Detection             | .11 |
| Phase 10: Production Readiness Scoring & Recommendations | .12 |
| Consolidated Action Plan                                 | .13 |

## Executive Summary .1

This report presents the findings of a comprehensive 10-phase audit of the Bait AI Mandi restaurant PWA application. The system is a **Next.js 14 (App Router)** application with **Supabase** backend (PostgreSQL + Auth + Realtime), **Drizzle ORM** for server-side reporting, **Zustand** for client state, and a fully custom **PWA layer** (Service Worker, IndexedDB, Background Sync, Push Notifications, Cache Invalidation via Realtime).

**Overall Readiness Score: 68/100 (⚠️ Production-ready with significant conditions)**

:Key Strengths

- Robust PWA architecture with idempotent background sync, cross-tab locking, and cache invalidation
- Strong security foundation: RLS policies, SSR auth middleware, role-based access control
- Clean layered architecture with clear separation of concerns
- Comprehensive database migration history (18 migrations)
- Optimistic concurrency control on orders table

:Critical Issues (must fix before production)

- `console.log/warn/error statements in production code` – leaks internal state, PII, and degrades performance
- No Realtime reconnection handling** – subscriptions silently die after WebSocket disconnect
- completely unused npm dependencies** (20KB+ bundle bloat each)
- No Content Security Policy header** – XSS mitigation missing
- Dual cart system with no synchronization** (Zustand localStorage vs IndexedDB)
- any types throughout repositories** – defeats TypeScript's type safety

.2 Project Statistics

| Value                                                             | Metric                           |
|-------------------------------------------------------------------|----------------------------------|
| 114                                                               | (.tsx / .ts) Source files        |
| 18                                                                | Database migrations              |
| tables + 7 enums 23                                               | Database tables (Drizzle schema) |
| 13 (dev) = 43 + (prod) 30                                         | npm dependencies                 |
| 7                                                                 | Unused dependencies              |
| 14                                                                | API routes                       |
| files, ~25 exported functions 5                                   | Server actions                   |
| 9                                                                 | Repositories                     |
| (SW, manifest, providers, IndexedDB, sync, invalidation, push) 10 | PWA-specific files               |
| files 6                                                           | Reports service (Drizzle)        |
| file 1                                                            | Tests                            |
| occurrences across 18 files 137                                   | /console.log/warn/error in src   |

Directory Breakdown

| Purpose                                               | Files      | Directory             |
|-------------------------------------------------------|------------|-----------------------|
| Next.js App Router pages + API routes                 | 36         | src/app/              |
| Server Actions (categories, items, orders, settings)  | 5          | src/actions/          |
| Data access layer (Supabase queries)                  | 9          | src/repositories/     |
| Drizzle-based analytics engine                        | 6          | src/services/reports/ |
| Utilities, PWA, Geo, Push, Cache, Sync                | sub 6 + 17 | src/lib/              |
| React components (layout, admin reports, invoice, UI) | 14         | src/components/       |
| Zustand cart store                                    | 1          | src/store/            |
| Drizzle schema + client                               | 2          | src/db/               |
| Zod validation schemas for reports                    | 1          | src/schemas/          |
| Zod schemas for orders                                | 1          | src/validators/       |
| Client-side cache (reports, settings)                 | 2          | src/cache/            |
| Supabase Realtime provider                            | 1          | src/realtime/         |
| Supabase client/server/middleware utils               | 3          | src/utls/supabase/    |
| Vitest tests                                          | 1          | src/__tests__/        |

### Phase 1: Architecture & Structure Analysis .3

#### Overall Architecture 3.1

:The system follows a **Hybrid Architecture** combining

- Next.js App Router** – file-based routing, server components, API routes
- Repository Pattern** – data access abstraction (Supabase queries)
- Server Actions** – business logic (createOrder, updateOrderStatus, etc.)
- Offline-First PWA** – Service Worker, IndexedDB, Background Sync
- Realtime Subscriptions** – Supabase Realtime for live updates
- Drizzle ORM** – server-side reporting queries

#### Layer Architecture 3.2

```
[UI Layer]
src/app/* (pages, layouts)
src/components/* (React components)
|
v
[Client State Layer]
src/store/cartStore.ts (Zustand + localStorage)
src/lib/settings-context.tsx (React Context)
src/realtime/OrderRealtimeProvider.tsx
src/lib/pwa/PwaProvider.tsx
|
v
[Data Access Layer - Client]
src/repositories/* (9 repositories, Supabase browser client)
src/cache/* (client-side in-memory cache)
src/lib/supabase.ts (browser client singleton)
|
v
[PWA Layer]
public/sw.js (Service Worker)
src/lib/db/indexeddb.ts (IndexedDB wrapper)
src/lib/sync/backgroundSync.ts (sync queue)
src/lib/cache/invalidation.ts (cache invalidation)
src/lib/push/pushNotifications.ts
|
v
[Server Layer]
src/actions/* (Server Actions)
src/app/api/* (API Routes)
src/middleware.ts (Auth middleware)
src/utils/supabase/server.ts (server client)
|
v
[Data Access Layer - Server]
src/repositories/orderServerRepository.ts
src/services/reports/* (Drizzle ORM)
src/db/index.ts (Drizzle client)
|
v
[Database]
PostgreSQL (Supabase)
RLS policies
Materialized views (reports)
```

### Architecture Quality Assessment 3.3

| Notes                                                     | Rating | Aspect                 |
|-----------------------------------------------------------|--------|------------------------|
| Good layering but some pages mix data access and UI       | 7/10   | Separation of concerns |
| Repository pattern helps but no barrel exports            | 7/10   | Modularity             |
| Widespread <code>any</code> types in repositories         | 4/10   | Type safety            |
| Inconsistent: some files have try-catch, others don't     | 5/10   | Error handling         |
| Only 1 test file, no mocking for Supabase/IndexedDB       | 3/10   | Testability            |
| Dual patterns: some use repos, some use supabase directly | 6/10   | Consistency            |

### Circular Dependency Check 3.4

**Result: NO circular dependencies found.** The dependency graph is acyclic with clear direction from leaf modules  
→ lib → repositories/actions → pages

## Phase 2: Dependency & Import Map Analysis .4

### Import Statistics 4.1

| Count           | Metric                       |
|-----------------|------------------------------|
| (.tsx + .ts) 86 | Total files analyzed         |
| 46              | Files using @/ alias         |
| 7               | Files using relative imports |
| 30              | Package-only imports         |

### Path Alias Map @/ 4.2

| Used By                                   | Maps To                      | Alias Path              |
|-------------------------------------------|------------------------------|-------------------------|
| modules (cache, repos, realtime, PWA) +10 | src/lib/supabase.ts          | @/lib/supabase          |
| modules (actions, API routes) +8          | src/utils/supabase/server.ts | @/utils/supabase/server |
| All frontend pages                        | src/lib/settings-context.tsx | @/lib/settings-context  |
| Pages + Navbar                            | src/store/cartStore.ts       | @/store/cartStore       |
| Services/reports                          | src/db/index.ts              | @/db                    |
| Services/reports                          | src/db/schema.ts             | @/db/schema             |
| PWA modules                               | src/lib/pwa/types.ts         | @/lib/pwa/types         |

### Most Imported Modules (Hotspots) 4.3

| Count | Imported By                                       | Module                           |
|-------|---------------------------------------------------|----------------------------------|
| 12~   | cache, repositories, realtime, PWA, gallery, push | @/lib/supabase                   |
| 10~   | actions, API routes, orderServerRepo              | @/utils/supabase/server          |
| 15~   | All public pages + admin pages + layout           | @/lib/settings-context           |
| 5~    | Navbar, cart, my-orders, menu pages               | @/store/cartStore                |
| 8~    | layout, settings-context, admin pages             | @/realtime/OrderRealtimeProvider |

### Leaf Modules (Zero Dependencies on Project) 4.4

- src/lib/constants.ts
- src/lib/currency.ts
- src/lib/delivery-pricing.ts
- src/lib/delivery-routing.ts
- src/lib/formatUtils.ts
- src/lib/location-validation.ts
- src/lib/offer-pricing.ts

- src/lib/permissions.ts •
- src/lib/printReport.ts •
- src/lib/supabase.ts •
- src/lib/validation.ts •
- src/lib/whatsapp-message.ts •
- src/lib/pwa/types.ts •
- src/lib/geo/resolve-location.ts •
- src/lib/maps/getDeliveryRoute.ts •
- src/db/schema.ts •
- src/schemas/reports.ts •
- src/store/cartStore.ts •
- src/validators/orderSchema.ts •

Cross-Layer Dependency Rules 4.5

```
Leaf modules → lib/ → repositories/ → actions/ → app/ pages
Leaf modules → lib/ → realtime/ → app/ layout
lib/ → cache/ → app/ pages
db/ → services/reports/ → app/api/reports/
utils/supabase/ → actions/ + app/api/ + middleware/
```

Phase 3: Package & Dependency Audit .5

Used Dependencies (Verified by import analysis) 5.1

| Version    | Used In                                                                  | Package               |
|------------|--------------------------------------------------------------------------|-----------------------|
| 0.3.0^     | src/utils/supabase/*                                                     | @supabase/ssr         |
| 2.106.1^   | src/realtime/OrderRealtimeProvider.tsx                                   | @supabase/supabase-js |
| 7.3.5^     | src/lib/geo/*                                                            | @turf/turf            |
| 0.30.10^   | src/db/* , src/services/reports/*                                        | drizzle-orm           |
| 4.4.0^     | src/lib/exportExcel.ts                                                   | exceljs               |
| 11.2.6^    | src/app/page.tsx                                                         | framer-motion         |
| 1.4.1^     | src/components/invoice/InvoiceModal.tsx                                  | html2canvas           |
| 4.2.1^     | src/components/invoice/InvoiceModal.tsx                                  | jspdf                 |
| 1.9.4^     | src/app/admin/delivery/page.tsx                                          | leaflet               |
| 0.379.0^   | Multiple components                                                      | lucide-react          |
| 14.2.3     | Everywhere                                                               | next                  |
| 8.0.10^    | src/app/api/reports/schedule/route.ts                                    | nodemailer            |
| 3.4.4^     | src/db/index.ts                                                          | postgres              |
| 1.5.4^     | src/app/admin/reports/page.tsx                                           | qrcode                |
| 4.2.0^     | src/components/invoice/InvoiceModal.tsx                                  | qrcode.react          |
| 18.3.1^    | Everywhere                                                               | react-dom / react     |
| 3.8.1^     | src/components/admin/reports/SummaryTab.tsx                              | recharts              |
| 4.4.3^     | , src/validators/* , src/schemas/*<br>src/repositories/menuRepository.ts | zod                   |
| 4.5.2^     | src/store/cartStore.ts                                                   | zustand               |
| (implicit) | src/lib/geo/resolve-location.ts                                          | rbush                 |
| 0.18.5^    | src/lib/exportExcel.ts                                                   | xlsx                  |
| 18.0.5^    | scripts/generate-pdfs.js                                                 | marked                |
| 25.1.0^    | scripts/generate-pdfs.js                                                 | puppeteer-core        |

## UNUSED Dependencies (Can be removed) 5.2

| Bundle Impact | Reason                            | Type       | Package                 |
|---------------|-----------------------------------|------------|-------------------------|
| +50KB~        | Never imported in any source file | production | 8.26.0^ @sentry/nextjs  |
| +30KB~        | Never imported in any source file | production | 1.131.4^ posthog-js     |
| +20KB~        | Never imported in any source file | production | 1.31.3^ @upstash/redis  |
| +100KB~       | Never imported in any source file | production | 3.12.5^ gsap            |
| +20KB~        | Never imported in any source file | production | 3.1.5^ dompurify        |
| Types only    | No corresponding runtime import   | dev        | 3.0.5^ @types/dompurify |
| +10KB~        | Never imported in any source file | production | 2.0.5^ file-saver       |
| +15KB~        | Never imported in any source file | production | 5.0.8^ jspdf-autotable  |
| N/A           | Next.js auto-loads .env files     | dev        | 17.4.2^ dotenv          |

Total potential bundle savings: ~250KB+ (gzipped: ~80KB+)

### Dependency Risk Assessment 5.3

| Issue                               | Package             | Risk             |
|-------------------------------------|---------------------|------------------|
| +Multiple CVEs patched in 14.2.15   | next@14.2.3         | Outdated Next.js |
| v5 is stable with breaking changes  | zustand@4.5.2       | Zustand v4       |
| v0.33+ has significant improvements | drizzle-orm@0.30.10 | Drizzle ORM      |
| +Latest is 5.7                      | typescript@5.4.5    | TypeScript       |

## Phase 4: Database & Migration Analysis .6

### Migration History Summary 6.1



| Tables Affected                                                                                                                                                                                                  | Description                   | Migration |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|-----------|
| users, admin_users, categories, items, item_prices, offers, offer_items, cart_sessions, cart_items, order_sequences, orders, order_items, order_status_history, gallery_images, reviews, site_settings, branches | Initial schema                | 0000      |
| admin_users, users                                                                                                                                                                                               | Auth + RLS refinements        | 0001      |
| Multiple tables                                                                                                                                                                                                  | Fix RLS policies              | 0002      |
| orders                                                                                                                                                                                                           | Add tracking_token            | 0003      |
| offers, offer_items                                                                                                                                                                                              | Add offer_bundles             | 0004      |
| customer_tokens                                                                                                                                                                                                  | Add customer_tokens           | 0005      |
| order_offers, order_offer_items                                                                                                                                                                                  | Add order_offers              | 0006      |
| offers                                                                                                                                                                                                           | Add variant_to_offers         | 0007      |
| zones table, deliveries                                                                                                                                                                                          | Add delivery_system           | 0008      |
| delivery_pricing, delivery_zones                                                                                                                                                                                 | Add new_delivery_pricing      | 0009      |
| order_delivery_snapshots                                                                                                                                                                                         | Add delivery_snapshot         | 0010      |
| gallery_images                                                                                                                                                                                                   | Add show_on_homepage          | 0011      |
| order_offer_items                                                                                                                                                                                                | Add order_offers_quantity     | 0012      |
| Multiple tables                                                                                                                                                                                                  | Add performance_indexes       | 0013      |
| mv_dashboard_summary, mv_sales_summary, mv_product_summary, mv_customer_summary                                                                                                                                  | Materialized_reports          | 0014      |
| Materialized views                                                                                                                                                                                               | Fix mv_indexes_and_refresh    | 0015      |
| orders (idempotency_key + unique partial index), push_subscriptions                                                                                                                                              | PWA_idempotency_and_hardening | 0016      |
| orders (version for OCC), audit_logs, rate_limiting, connection pooling config                                                                                                                                   | Production_hardening          | 0017      |

## Database Schema Health 6.2

| Notes                                                     | Rating | Aspect              |
|-----------------------------------------------------------|--------|---------------------|
| enums properly defined (admin_role, order_status, etc.) 7 | ✓      | Enum usage          |
| Performance indexes in migration 0013                     | ✓      | Indexes             |
| Proper referential integrity                              | ✓      | Foreign keys        |
| All tables have RLS enabled                               | ✓      | RLS policies        |
| reporting MVs with refresh mechanism 4                    | ✓      | Materialized views  |
| column on orders with conditional increment version       | ✓      | OCC                 |
| with unique partial index idempotency_key                 | ✓      | Idempotency         |
| Some columns lack NOT NULL that should have it            | ⚠      | Missing constraints |

## Schema vs Migration Drift Check 6.3

.All Drizzle schema definitions in src/db/schema.ts align with the migration history. No drift detected

## Phase 5: Security Audit .7

### Security Posture Summary 7.1

| Details                                                                        | Status            | Control             |
|--------------------------------------------------------------------------------|-------------------|---------------------|
| Enabled on all tables, with role-based access                                  | ✓                 | RLS Policies        |
| <code>/admin/:path* :matcher src/middleware.ts</code>                          | ✓                 | Admin Middleware    |
| Cookie-based Supabase SSR auth                                                 | ✓                 | SSR Auth            |
| developer, manager, order_manager roles                                        | ✓                 | Role-based Access   |
| and <code>get_admin_role()</code> use SECURITY DEFINER <code>is_admin()</code> | ✓                 | Security Definer    |
| No Content-Security-Policy header                                              | Missing ✗         | CSP                 |
| No rate limiting on auth endpoints or API routes                               | Missing ✗         | Rate Limiting       |
| Dev uses localhost certs                                                       | ⚠                 | HTTPS               |
| PII leakage risk                                                               | occurrences 137 ✗ | Console.log in prod |
| SW strips some but not all sensitive headers                                   | ⚠                 | Sensitive Headers   |

### Critical Security Issues 7.2

#### SEC-01: No Content Security Policy (Risk: HIGH)

**Location:** `next.config.js:13-38`

**Issue:** Missing `Content-Security-Policy` header. The current headers include `X-Content-Type-Options`, `X-Frame-Options`, `X-XSS-Protection`, and `Referrer-Policy`, but CSP is absent.

**Impact:** XSS attacks, data injection, unauthorized script execution.

**Fix:** Add CSP header in `next.config.js` headers configuration.

#### SEC-02: Console.log in Production (Risk: HIGH)

**Location:** 18 files, 137 occurrences

**Impact:** Leaks internal state, cookie names, request paths, user data. In `src/utils/supabase/middleware.ts:25`, cookie names are logged. In `src/app/api/auth/login/route.ts:16`, auth flow details are logged.

**Fix:** Remove all `console.log` calls from production code. Use proper logging library (e.g., `pino` or `winston`) if server-side logging is needed.

#### SEC-03: Cart Tables Have Open RLS (Risk: MEDIUM)

**Location:** `src/db/rls.sql:80-81`

**Issue:** `cart_sessions` and `cart_items` have `USING (true)` policies – any authenticated user can read/write any `.cart`.

**Impact:** Users could potentially read/modify other users' carts.

**Fix:** Add session-based or user-based filters to cart RLS policies.

#### SEC-04: Reviews Allow Unauthenticated Insert (Risk: MEDIUM)

src/db/rls.sql:71 :Location

.Issue: Anyone can insert reviews — no auth required, no rate limiting

.Impact: Spam reviews, database flooding

.Fix: Add rate limiting + maybe require auth for reviews

#### SEC-05: No Rate Limiting on Auth Endpoints (Risk: MEDIUM)

src/app/api/auth/login/route.ts :Location

.Issue: No rate limiting on login attempts

.Impact: Brute force attack vulnerability

.Fix: Implement rate limiting (e.g., Upstash Redis or in-memory with @upstash/ratelimit )

#### SEC-06: Service Worker Can Intercept All Requests (Risk: MEDIUM)

public/sw.js:470-531 :Location

.Issue: The SW's fetch event handler intercepts all requests including potentially sensitive ones

.Impact: A bug in SW could leak or modify sensitive data

.Fix: Add URL allowlist/blocklist for SW interception; review stripSensitiveHeaders completeness



#### Security Good Practices 7.3

- RLS with SECURITY DEFINER functions
- Admin middleware restricts /admin/\* routes
- Role-based access control (developer, manager, order\_manager)
- Hard delete prevention on orders ( prevent\_orders\_delete rule)
- OCC via version column
- Idempotency keys prevent duplicate orders
- Headers: X-XSS-Protection: 1; mode=block , X-Frame-Options: DENY , X-Content-Type-Options: nosniff

## Phase 6: PWA & Offline Capability Audit .8

### PWA Component Health 8.1

| Notes                                                   | Risk     | Status     | Component                |
|---------------------------------------------------------|----------|------------|--------------------------|
| lines, 5 cache stores, background sync, push 602        | Critical | Functional | ( sw.js ) Service Worker |
| Icons only use one image (logo.png) for all sizes       | High     | Configured | Web App Manifest         |
| Registration, install prompt, online detection, cleanup | Critical | Functional | PwaProvider              |
| object stores, typed operations 5                       | Critical | Functional | IndexedDB Wrapper        |
| Idempotent, cross-tab lock, exponential backoff         | Critical | Functional | Background Sync          |
| Single Realtime channel, targeted cache clearing        | High     | Functional | Cache Invalidation       |
| VAPID key may be unconfigured                           | Medium   | Partial    | Push Notifications       |
| Basic fallback, no useful content                       | Low      | Minimal    | Offline Page             |

Cache Strategy Analysis 8.2

| Risk                                                                                                       | TTL              | Strategy             | Cache Name      |
|------------------------------------------------------------------------------------------------------------|------------------|----------------------|-----------------|
| Low                       | Permanent        | CacheFirst           | static-v1       |
| Low                       | On every request | StaleWhileRevalidate | pages-v1        |
| Order cache TTL too long  | minutes 5        | NetworkFirst         | api-supabase-v1 |
| Reports can go stale      | No TTL           | NetworkFirst         | api-reports-v1  |
| Low                       | Permanent        | CacheFirst           | assets-v1       |

Critical PWA Issues 8.3

PWA-01: No Realtime Reconnection Handling (Risk: CRITICAL)

`src/realtime/OrderRealtimeProvider.tsx` :Location

**Issue:** No explicit reconnection handling. When Supabase WebSocket disconnects, subscriptions are not re-established.

**Impact:** Admin stops seeing new orders; cache invalidation stops working

**Fix:** Add `onReconnect` handler in Supabase channel subscription

PWA-02: No Periodic Sync (Risk: MEDIUM)

`public/sw.js` :Location

**Issue:** No periodic sync registration. Background sync only triggers on explicit `sync.register()` or online event

**Impact:** If user closes all tabs while items are queued, sync may not complete

`pwa-sync-queue` **Fix:** Register `periodicSync` event with tag

PWA-03: FormData Requests Not Handled (Risk: LOW)

`public/sw.js:374-375` :Location

**Issue:** SW assumes all request bodies are JSON strings

**Impact:** If any mutation uses FormData, it will be corrupted when queued

**Fix:** Add FormData detection and serialization in SW fetch handler

PWA-04: VAPID Key Not Configured (Risk: MEDIUM)

`src/lib/push/pushNotifications.ts:4-5` :Location

**Issue:** `process.env.NEXT_PUBLIC_VAPID_PUBLIC_KEY` may be empty

**Impact:** Push notification subscription will fail silently

**Fix:** Add VAPID key validation and user-friendly error

PWA-05: Single Queue Lock (Risk: MEDIUM)

`src/lib/sync/backgroundSync.ts` :Location

**Issue:** One lock for all tenants/users

**Impact:** At high concurrency, queue processing becomes a bottleneck

**Fix:** Implement per-tenant or per-user queue locks

PWA-06: No Sync Retry Limit Reset (Risk: MEDIUM)

- .Issue:** When a pending item is retried and fails again, `retryCount` is not reset
- .Impact:** Items eventually reach `maxRetries` and are permanently marked as failed
- .Fix:** Add periodic retry count reset for failed items



#### PWA Good Practices 8.4

- Idempotency keys on order mutations (both in JS and SQL) •
- Cross-tab queue locking via IndexedDB •
- Stale processing recovery (items stuck in 'processing' state) •
- Heartbeat mechanism for queue lock ownership •
- Cache invalidation via single Realtime channel •
- Exponential backoff with jitter •
- BroadcastChannel for cross-tab coordination •

## Phase 7: Performance Analysis .9

### Performance Bottlenecks 9.1

#### PERF-01: createOrder Server Action (Risk: HIGH)

**Location:** `src/actions/orders.ts:171-621` (450 lines)

**.Issue:** Single function performs 10+ sequential database operations

- Fetch delivery settings .1
- Calculate delivery fee .2
- Get order sequence with optimistic locking (up to 10 retries) .3
- Insert order .4
- Insert order items (loop) .5
- Insert order offers (loop) .6
- Insert order offer items (loop) .7
- Insert order status history .8
- Log to audit logs .9

- .Impact:** Each order creation takes 500ms-2s. Under load, this becomes a bottleneck
- .Fix:** Decompose into smaller services; use database transactions efficiently

#### PERF-02: No Pagination in Order Items Fetch (Risk: MEDIUM)

**Location:** `src/repositories/orderRepository.ts`

- .Issue:** `getOrdersClient` fetches all order items without pagination
- .Impact:** As order volume grows, memory usage increases linearly
- .Fix:** Add LIMIT/OFFSET or cursor-based pagination

#### PERF-03: Sequential Sync Queue Processing (Risk: MEDIUM)

src/lib/sync/backgroundSync.ts:171-214 :Location

.Issue: Queue items are processed one-by-one sequentially

.Impact: With 100+ queued items, sync can take several minutes

.Fix: Implement batch processing or parallel processing with concurrency control

PERF-04: Cache Invalidation Loop (Risk: LOW)

src/lib/cache/invalidation.ts:56-73 :Location

.Issue: Cache entries are deleted one-by-one in a map() loop

.Impact: Minor performance impact during invalidation

.Fix: Use Promise.all (already used) but consider batch operations

PERF-05: Console.log in Hot Paths (Risk: MEDIUM)

Location: Multiple files

.Issue: console.log calls in frequently executed code paths (middleware, auth, orders)

.Impact: Adds unnecessary overhead to every request

.Fix: Remove all production console.log calls

Bundle Size Analysis 9.2

| Category                                  | Estimated Size | Package             |
|-------------------------------------------|----------------|---------------------|
| CSS + JS (dynamic import mitigates)       | 150KB~         | leaflet             |
| Large visualization library               | 200KB~         | recharts            |
| Heavy XLSX generation                     | 500KB~         | exceljs             |
| Animation library (only used on homepage) | 100KB~         | framer-motion       |
| PDF generation (only in invoice modal)    | 200KB~         | html2canvas + jspdf |

Recommendation: Verify that dynamic imports are used for heavy libraries (leaflet is dynamically imported in

admin/delivery/page.tsx )

Performance Score: 68/100 9.3

Phase 8: Business Logic & State Management Audit .10

State Management Assessment 10.1

| Issues                 | Scope        | Storage      | Type   | State System                       |
|------------------------|--------------|--------------|--------|------------------------------------|
| No cross-tab sync ❌    | Per tab      | localStorage | Client | <b>Cart</b> (Zustand)              |
| No sync with Zustand ❌ | Per SW scope | IndexedDB    | Client | <b>Cart</b> (IndexedDB)            |
| Refresh on Realtime ✅  | App-wide     | In-memory    | Client | <b>Settings</b> (Context)          |
| ✅                      | App-wide     | In-memory    | Client | <b>PWA State</b> (Context)         |
| No reconnection ❌      | App-wide     | In-memory    | Client | <b>Realtime</b> (Context)          |
| ✅                      | Request      | Cookies      | Server | <b>Auth</b> (Supabase SSR)         |
| ✅                      | Admin layout | In-memory    | Client | <b>Admin Permissions</b> (Context) |

## Critical Business Logic Issues 10.2

### BIZ-01: Dual Cart System (Risk: HIGH)

**Location:** `src/store/cartStore.ts` (Zustand/localStorage) vs `src/lib/db/indexeddb.ts` (IndexedDB)

**Issue:** Cart exists in two places with no synchronization mechanism

- Zustand cart is used for UI display
- IndexedDB `offlineCart` store is used for PWA offline orders
- When user adds items offline, Zustand cart may be empty while IndexedDB has items
- **Impact:** Lost cart items, duplicate orders, user confusion

**Fix**

- Option A: Use IndexedDB as the single source of truth, derive Zustand state from it
- Option B: Sync Zustand → IndexedDB on every cart mutation

### BIZ-02: Duplicate Checkout Logic (Risk: MEDIUM)

**Location:** `src/app/my-orders/page.tsx` and `src/app/cart/page.tsx`

**Issue:** Both pages contain independent checkout logic (~1200 lines combined)

**Impact:** Bug fixes must be applied to two places; maintenance burden

**Fix:** Extract checkout into a shared component or hook

### BIZ-03: No Order Rollback on Partial Failure (Risk: MEDIUM)

**Location:** `src/actions/orders.ts` (order creation)

**Issue:** If order creation fails after inserting some related records (e.g., order items succeed but order offers fail), there is no rollback

**Impact:** Orphaned records, inconsistent state

**Fix:** Wrap order creation in a database transaction

### BIZ-04: Multi-Tab Race Condition in Cart (Risk: MEDIUM)

**Location:** `src/store/cartStore.ts`

**Issue:** Zustand persist middleware uses localStorage. Multiple tabs can overwrite each other's cart state

**Impact:** Lost cart items when using multiple tabs

**Fix:** Implement BroadcastChannel-based cross-tab cart sync (similar to queue lock approach)



## Business Logic Good Practices 10.3

- Optimistic concurrency control on order updates
- Unique order number generation with retry logic
- Tracking tokens for customer order lookup
- Idempotency keys to prevent duplicate orders
- Delivery fee calculation with zone-based pricing
- Minimum order amount validation
- Phone number validation and normalization for Yemen

## Phase 9: Dead Code & Unused Assets Detection .11

### Unused Files 11.1

| Evidence                                                                         | Status                  | File                       |
|----------------------------------------------------------------------------------|-------------------------|----------------------------|
| Listed in initial inventory but file not found on disk – possible build artifact | Does not exist ❌        | src/app/middleware.ts      |
| Not called by any build process                                                  | Exist but unused ⚠️     | scripts/convert-to-pdf.mjs |
| Manual testing, not integrated into test suite                                   | Root-level test ⚠️ file | test-db.ts                 |

### Unused Exports (Identified by Single-User Pattern) 11.2

| Status                                       | Used By                   | File                      | Export                 |
|----------------------------------------------|---------------------------|---------------------------|------------------------|
| Used ✅                                       | Only categories.ts action | categoryRepository.ts     | getCategorySortOrder   |
| Unused ⚠️                                    | Nowhere in source         | lib/cache/invalidation.ts | registerTableMapping   |
| Unused ⚠️                                    | Nowhere in source         | lib/cache/invalidation.ts | getUrlPatternsForTable |
| Used internally ✅                            | Only invalidateCache      | lib/cache/invalidation.ts | getCacheKeysForTable   |
| Unused (callers use invalidateCacheViaSW) ⚠️ | Nowhere in source         | lib/cache/invalidation.ts | invalidateCache        |
| Most used ✅                                  | PWA modules               | lib/pwa/types.ts          | Various PWA types      |

**Note:** registerTableMapping , invalidateCache , getUrlPatternsForTable are exported but never imported anywhere in the codebase. They appear to be a public API that was never consumed

### Unused Public Assets 11.3



| Status                                       | Asset                    |
|----------------------------------------------|--------------------------|
| Unused – default Next.js file ❌              | public/file.svg          |
| Unused – default Next.js file ❌              | public/globe.svg         |
| Unused – default Next.js file ❌              | public/next.svg          |
| Unused – default Next.js file ❌              | public/vercel.svg        |
| Unused – default Next.js file ❌              | public/window.svg        |
| Unused – duplicate/backup of logo-new.png ❌  | public/logo-new copy.png |
| Used – referenced as favicon in layout.tsx ✅ | public/logo.jpg          |
| Used – PWA icon, SW precache ✅               | public/logo.png          |
| Possibly unused – not referenced in code ⚠️  | public/logo-new.png      |

Dead Code in Source 11.4

| Lines           | Issue                                                        | Location                          |
|-----------------|--------------------------------------------------------------|-----------------------------------|
| 28~ occurrences | statements used as debug console.error / console.log logging | src/actions/orders.ts             |
| occurrences 3   | Debug console.log statements                                 | src/app/admin/categories/page.tsx |
| occurrences 11~ | Extensive debug logging                                      | src/lib/maps/getDeliveryRoute.ts  |

Phase 10: Production Readiness Scoring & Recommendations .12

Scoring Matrix (Updated from Previous 70/100) 12.1

| Key Factors                                               | Change | Score    | Category        |
|-----------------------------------------------------------|--------|----------|-----------------|
| Good layering, but type safety gap remains                | →      | 72/100   | Architecture    |
| Well-structured with indexes, OCC, idempotency            | →      | 80/100   | Database        |
| CSP missing, 137 console.log in prod (PII leak)           | 13- ↓  | 72/100   | Security        |
| Robust but no reconnection handling                       | →      | 75/100   | PWA Layer       |
| Basic but limited (no offline menu/browse)                | →      | 70/100   | Offline Support |
| Critical: no reconnection handling                        | 10- ↓  | 55/100   | Realtime        |
| Heavy createOrder, no pagination                          | 2- ↓   | 68/100   | Performance     |
| Dual cart, no rollback, missing error boundaries          | 3- ↓   | 65/100   | Reliability     |
| console.log, any types, duplicate checkout code 137       | 5- ↓   | 55/100   | Maintainability |
| Single queue lock, no rate limiting, no batch processing  | 5- ↓   | 50/100   | Scalability     |
| Significant regression due to console.log and missing CSP | 4.8- ↓ | 66.2/100 | TOTAL           |

## Critical Recommendations (Must Fix Before Production) 12.2

### C-01: Remove All Production console.log Statements

**Risk:** CRITICAL | **Effort:** 1-2 hours | **Files:** 18 files (137 occurrences)

**Action:** Audit and remove all `console.log`, `console.warn`, `console.error` from production code paths. Use `.structured logging` (Pino/Winston) for server-side only if needed

### C-02: Add Realtime Reconnection Handling

`src/realtime/OrderRealtimeProvider.tsx` **:Risk:** CRITICAL | **Effort:** 2-4 hours | **File**

**Action:** Add `onReconnect` handler to Supabase channel subscription. On reconnection, re-subscribe to all active `.channels`

### C-03: Add Content Security Policy Header

`next.config.js` **:Risk:** HIGH | **Effort:** 1 hour | **File**

**Action:** Add `Content-Security-Policy` header in the Next.js headers configuration

### C-04: Remove Unused Dependencies

`package.json` **:Risk:** HIGH | **Effort:** 30 min | **File**

**Action:** Remove 7 unused production dependencies to reduce bundle size by ~250KB

### C-05: Fix Dual Cart System

`src/lib/db/indexeddb.ts`, `src/store/cartStore.ts` **:Risk:** HIGH | **Effort:** 4-8 hours | **Files**

**Action:** Unify cart storage. Option: Use IndexedDB as single source of truth, derive Zustand state from it

## High Priority Recommendations 12.3

### H-01: Add Application-Layer Rate Limiting

**Risk:** HIGH | **Effort:** 2-4 hours

**Action:** Implement rate limiting on auth endpoints, order creation, and reviews

### H-02: Add TypeScript Strict Types to Repositories

**Risk:** HIGH | **Effort:** 8-16 hours

**Action:** Replace `any` with proper TypeScript types in all 9 repository files

### H-03: Implement Cross-Tab Cart Synchronization

**Risk:** MEDIUM | **Effort:** 4-6 hours

**Action:** Use BroadcastChannel to sync cart state across tabs

### H-04: Decompose createOrder Server Action

**Risk:** MEDIUM | **Effort:** 8-12 hours

**Action:** Split 450-line function into smaller, testable services

### H-05: Fix RLS Policies for Cart Tables

**Risk:** MEDIUM | **Effort:** 1-2 hours

**Action:** Update `cart_sessions` and `cart_items` RLS policies to use proper session-based filtering

## Medium Priority Recommendations 12.4

### M-01: Add Periodic Sync to Service Worker

**Risk:** MEDIUM | **Effort:** 2-3 hours

**Action:** Register `periodicSync` event for background queue processing

### M-02: Add Pagination to Order Queries

**Risk:** MEDIUM | **Effort:** 4-6 hours

**Action:** Add LIMIT/OFFSET to all order list queries in repositories

### M-03: Add IndexedDB Quota Monitoring

**Risk:** MEDIUM | **Effort:** 2-3 hours

**Action:** Monitor storage usage and warn users before quota is exceeded

### M-04: Add Error Boundary Around PwaProvider

**Risk:** MEDIUM | **Effort:** 1 hour

**Action:** Wrap PwaProvider in React Error Boundary to prevent app crash if PWA fails

### M-05: Implement Order Creation Database Transaction

**Risk:** MEDIUM | **Effort:** 3-5 hours

**Action:** Wrap order creation in a proper database transaction with rollback on failure

## Low Priority Recommendations 12.5

### L-01: Remove Unused Public Assets

**Risk:** LOW | **Effort:** 15 min

**Action:** Delete `logo-new copy.png` , `window.svg` , `vercel.svg` , `next.svg` , `globe.svg` , `file.svg`

### L-02: Implement Batch Queue Processing

**Risk:** LOW | **Effort:** 4-8 hours

**Action:** Process sync queue items in batches of 5-10 for better throughput

### L-03: Improve Offline Page

**Risk:** LOW | **Effort:** 2-3 hours

**Action:** Add useful content to offline page (phone number, address, cached menu)

### L-04: Add FormData Support in Service Worker

**Risk:** LOW | **Effort:** 2 hours

**Action:** Handle FormData request bodies in SW fetch interceptor

### L-05: Create Missing Test Suite

**Risk:** LOW | **Effort:** 20+ hours

**Action:** Add unit tests for PWA, business logic, and API routes

## Consolidated Action Plan .13

### By Priority

| Total Effort  | Items             | Priority |
|---------------|-------------------|----------|
| hours 10-16~  | C-01 through C-05 | Critical |
| hours 23-40~  | H-01 through H-05 | High     |
| hours 12-18~  | M-01 through M-05 | Medium   |
| hours 28-33~  | L-01 through L-05 | Low      |
| hours 73-107~ | items 20          | TOTAL    |

### By Impact

| Timeline      | Effort | Items                        | Impact                            |
|---------------|--------|------------------------------|-----------------------------------|
| Before launch | 10-17h | C-02, C-03, C-05, H-01, H-05 | Security & Stability 🚒            |
| Sprint 1      | 16-24h | C-01, C-04, H-04, M-02, L-02 | Bundle & Performance 📦            |
| Sprint 2      | 24-35h | H-02, H-03, M-04, M-05, L-05 | Architecture & Maintainability 🏗️ |
| Sprint 2-3    | 9-15h  | C-02, M-01, M-03, L-03, L-04 | PWA & Offline 📶                   |
| Before launch | 1h>    | C-04, L-01                   | Cleanup 🧹                         |

## Appendix: Previous Audit Cross-Reference

The previous architectural audit ( docs/التدقيق\_المعماري\_وتحليل/PWA.md ) scored the project at 70/100.  
 :This extended audit finds the score has **declined to ~66/100** due to

**Unresolved** : Realtime reconnection, console.log, type safety, single queue lock – all identified previously .1  
 but not yet addressed

**New findings:** CSP missing, 7 unused dependencies, dual cart system, no cross-tab cart sync, FormData .2  
 gap

**Improved areas:** VAPID key was identified previously as possibly unconfigured – still not verified (ME-04) .3

## Conclusion

The Bait AI Mandi project has a **strong architectural foundation** with well-implemented PWA capabilities, security controls, and database design. However, it suffers from **accumulated technical debt** (137 console.log statements, any types, dual cart system) and **missing critical features** (CSP, Realtime reconnection, rate limiting) that must .be addressed before production deployment

**Estimated time to production readiness:** 2-3 weeks (with 1 developer)

**Estimated effort:** 73-107 hours total across 20 identified issues

**Priority:** Fix C-01 through C-05 first (10-16 hours) for a minimum viable production launch

---

*Report generated by automated system-wide audit | 18 June 2026 | Tools: static code analysis, import map verification, dependency cross-reference, grep-based usage analysis*